

Fiche Mémo : IA Générative et Risques de Sécurité Cachés

Notes et synthèse sur le rapport de Secure Code Warrior (ISMG)

1. Ce qu'il faut retenir (L'idée principale)

L'utilisation massive d'assistants de code basés sur l'Intelligence Artificielle (GitHub Copilot, ChatGPT, Cursor) fait exploser la vitesse de développement. Cependant, un **danger invisible s'installe au cœur du code source** : ces outils ont été entraînés sur de l'open-source contenant des erreurs historiques, et ils ont tendance à **reproduire et automatiser l'injection de failles de sécurité**.

2. Les 3 grands risques à surveiller de près

- **L'apparition de vulnérabilités classiques OWASP** : Les outils d'IA proposent fréquemment des blocs de code qui réintroduisent des erreurs critiques et bien connues, notamment des **injections SQL**, des failles **XSS (Cross-Site Scripting)** ou des mauvaises gestions des privilèges.
- **Le piège de la confiance aveugle** : Les développeurs, souvent pressés par le temps, ont tendance à copier-coller les suggestions de l'IA sans effectuer de **revue de code approfondie**. Cela crée un faux sentiment de sécurité.
- **La conformité et fuites de données (RGPD)** : Envoyer des portions de code d'entreprise vers des API cloud tierces sans contrôle expose à des risques sévères de fuites de données confidentielles ou de clés d'API.

Note de vigilance (Bonnes pratiques de code)

L'IA est un assistant formidable pour écrire du code répétitif, mais elle ne remplace pas le développeur. Notre valeur ajoutée consiste à rester le garde-fou : **auditer rigoureusement chaque ligne générée**, valider la sécurité applicative et s'assurer qu'aucune donnée sensible ne quitte l'environnement sécurisé.

3. Solutions et réflexes à adopter

Il est impératif d'associer l'usage de l'IA à des outils d'analyse statique automatisés (**scanners SAST**) intégrés au projet pour intercepter les erreurs de sécurité au plus tôt (philosophie **Shift Left**). Pour des projets professionnels sensibles, l'usage d'**IA hébergées localement (comme Ollama)** s'avère indispensable pour sanctuariser le code.